

SENTINAL SECURITY AUDIT REPORT

Target Scope: None | Scan Mode: STANDARD | Auth: DEV_MODE | Date: September 08, 2026 at 08:42 UTC

Security Score	DAST Coverage	Critical Flaws	High Flaws	Total Findings
92.0/100	100.0% (NOT_APPLICABLE)	9	12	32

2. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** CRITICAL POSTURE

The automated assessment of None identified immediate critical exposures requiring urgent remediation. A total of 32 findings were recorded, including 9 Critical and 12 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 32 (Critical: 9, High: 12, Medium: 11, Low: 0)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Injection, Container Security

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

4. Prioritized Vulnerability & Threat Inventory

Severity & Risk	Engine	Vulnerability & Threat Scenario	Location & Remediation
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	Dockerfile Fix: Add `USER nonroot` or a dedicated unprivileged user before the ENTRYPOINT/CMD...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	data/static/codefixes/chatbotGreedyInjectionChallenge_1.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	data/static/codefixes/chatbotGreedyInjectionChallenge_2_correct.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	data/static/codefixes/chatbotGreedyInjectionChallenge_3.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	data/static/codefixes/chatbotGreedyInjectionChallenge_4.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...

HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	frontend/src/assets/private/dat.gui.min.js Fix: Use `textContent` or sanitize user input using DOMPurify before inserting into the DOM...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	frontend/src/assets/private/stats.min.js Fix: Use `textContent` or sanitize user input using DOMPurify before inserting into the DOM...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	frontend/src/assets/private/three.js Fix: Use `textContent` or sanitize user input using DOMPurify before inserting into the DOM...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	frontend/src/hacking-instructor/index.ts Fix: Use `textContent` or sanitize user input using DOMPurify before inserting into the DOM...
HIGH Risk: 86.6/100 Blast: Session Hijacking & Clie	SAST sentinal-sast	Cross-Site Scripting (XSS) via innerHTML / dangerouslySetInnerHTML Threat: An adversary can inject malicious JavaScript into the victim's browser session, stealing session tokens and cookies, rewriting web pages for credential phishing, or forcing unautho..	frontend/src/hacking-instructor/helpers/helpers.ts Fix: Use `textContent` or sanitize user input using DOMPurify before inserting into the DOM...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure & R	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	infrastructure/Dockerfile Fix: Add `USER nonroot` or a dedicated unprivileged user before the ENTRYPOINT/CMD...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	lib/xml.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	routes/b2bOrder.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	routes/captcha.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	routes/chat.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...

HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	routes/showProductReviews.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...
HIGH Risk: 94.3/100 Blast: Database Takeover & Sens	SAST sentinal-sast	Potential NoSQL Injection Threat: An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..	routes/trackOrder.ts Fix: Sanitize query keys using mongo-sanitize or enforce strict schema validation...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	routes/userProfile.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	test/cypress/e2e/basket.spec.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
CRITICAL Risk: 100.0/100 Blast: Full Server Takeover & R	SAST sentinal-sast	Arbitrary Code Execution via eval() or Dynamic Function Threat: An adversary can execute arbitrary operating system commands with web process privileges, allowing them to spawn reverse shells, install backdoors/ransomware, and pivot laterally i..	test/cypress/e2e/contact.spec.ts Fix: Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures...
MEDIUM Risk: 42.1/100 Blast: Information Disclosure &	SAST sentinal-sast	Dockerfile Container Running as Root Threat: The vulnerability exposes implementation details, internal software versions, or unhardened endpoints that assist attackers in reconnaissance and multi-stage attack chaining...	test/smoke/Dockerfile Fix: Add `USER nonroot` or a dedicated unprivileged user before the ENTRYPOINT/CMD...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: body-parser (1.20.4) - GHSA-v422-hmww-36x6 Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	package.json Fix: Upgrade sanitize-html to a secure version. Upgrade to latest version...
MEDIUM Risk: 54.5/100 Blast: Third-Party Component Ex	SCA osv-scanner	Vulnerable Dependency: @angular/common (22.0.1) - GHSA-jhpb-976m-542j Threat: An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..	frontend/package.json Fix: Upgrade @angular/common to a secure version. Upgrade to latest version...
MEDIUM Risk: 60.6/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: JSON Web Token (JWT) Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	frontend/src/app/app.guard.spec.ts Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..
MEDIUM Risk: 60.6/100 Blast: Cloud & Third-Party Serv	SECRETS gitleaks	Exposed Secret: JSON Web Token (JWT) Threat: Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..	frontend/src/app/last-login-ip/last-login-ip.component.spec.ts Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v..

5. Strategic Remediation Playbook

****Step-by-Step Remediation Actions:****

- ****Code Execution:**** Avoid ``eval()`` and ``new Function()``. Use structured JSON parsers or declarative data structures.